

Sakred App — Compliance-Oriented System Audit & Private-Sector Redesign Plan

Source of truth: codebase as of 2026-02-12. No documentation treated as authoritative.

A) CURRENT APP INVENTORY

A1. Tech Stack & Runtime

Layer	Technology	Config File
Framework	React Native (Expo managed workflow)	app.json, app.config.js
Language	TypeScript	tsconfig.json
Build	EAS Build + auto-submit (iOS/Android)	eas.json
Backend	Supabase (Postgres + Auth + Storage + Edge Functions)	supabase.ts
Payments	Stripe (web) + native IAP via react-native-iap	stripe.ts, iap.ts
AI	OpenAI / Anthropic via Supabase Edge Functions	utils/aiService.ts

Targets	iOS 13+, Android (minSdk from Expo defaults), Web (partial)	app.json
Current version	1.0.4 (iOS buildNumber 96, Android versionCode 10)	app.json

Environment variables (13 client-side `EXPO_PUBLIC_*` + ~20 server-side Edge Function secrets) loaded from EAS build profile `production.env` in `eas.json`.

A2. Navigation Map

Root (RootNavigator.tsx): conditional on auth + onboarding state → `Auth` | `Onboarding` | `MainTabs`

MainTabs (MainTabNavigator.tsx):

T a b	Stack	Routes
H o m e	Dashboa rdStack	<code>Dashboard</code> → <code>RoutineSelection</code> , <code>RoutineWalkthrough</code> , <code>Journal</code> , <code>JournalEntry</code> , <code>Rewards</code> , <code>Analytics</code> , <code>Wearables</code> , <code>DreamDiary</code>
H a b i t s	HabitsSt ack	<code>HabitsMain</code> → <code>HabitEncyclopedia</code> , <code>RoutineSelection</code> , <code>RoutineWalkthrough</code>
C r e a t e	(<i>FAB</i> → <i>navigate s to</i> <code>Routine Selecti on</code>)	—

C o a c h	AICoach Screen (no stack)	—
P r o f i l e	ProfileStack	ProfileMain → Settings, Notifications, Subscription, Wearables, KnowledgeBase, AITraining, AdminDashboard, TopicRequests, ManageRoutines, ManageHabits, ManageProducts
Total registered routes: 31 (3 root + 5 tabs + 8 Dashboard + 4 Habits + 12 Profile, minus 1 dummy).		

A3. Features List (derived from screens)

Feature	Screen(s)	Health-data ?
Email/Apple/Google auth	AuthScreen	No
Onboarding (gender, birthday, goals, theme)	OnboardingScreen	Yes (gender, DOB)
Dashboard with 14-day journey map + habit checkboxes	DashboardScreen	Yes
Routine browsing, filtering, enrollment (lite/intense)	RoutineSelectionScreen	Yes
Routine walkthrough (first-time)	RoutineWalkthroughScreen	No
Daily habits with completion toggles	HabitsScreen	Yes

Habit encyclopedia / catalog (assign + custom)	HabitsEncyclopediaScreen	Yes
Journal entries with mood (1-5) + voice input	JournalScreen, JournalEntryScreen	Yes (mood, content)
Dream diary with emotion/theme tagging	DreamDiaryScreen	Yes (mental health)
Menstrual cycle tracking (phase, flow, symptoms)	CycleTrackingScreen	Yes (PHI)
AI Coach (terrain-theory translator + conversational chat)	AICoachScreen	Yes (aggregates all)
Wearable connections (Fitbit, WHOOP, Oura, Garmin)	WearablesScreen	Yes (biometrics)
Analytics / trends (7d/30d/90d)	AnalyticsScreen	Yes
Gamification (Sakred Coins, streaks, badges)	RewardsScreen	No
Subscription / paywall (IAP + Stripe)	SubscriptionScreen	No
Personal knowledge base (doc uploads)	KnowledgeBaseScreen	Yes (documents)
Push notification preferences	NotificationsScreen	Yes (cycle alerts)

Profile + settings + account deletion	ProfileScreen, SettingsScreen	Yes (PII)
Admin: Dashboard, AI training docs, topic requests, routine/habit/product CRUD	AdminDashboardScreen, AITrainingScreen, AdminTopicRequestsScreen, RoutinesManagementScreen, HabitsManagementScreen, ProductsManagementScreen	No

A4. Auth Model & Session Handling

Source: AuthContext.tsx

- **Methods:** Email/password, Apple Sign-In (`expo-apple-authentication`), Google OAuth (Supabase-hosted flow)
- **Session storage:** Supabase JS client persists JWT access + refresh tokens via **AsyncStorage** (plaintext, unencrypted)
- **Auto-refresh:** `autoRefreshToken: true, detectSessionInUrl: true`
- **Foreground refresh:** Re-calls `getSession()` on AppState `active`
- **Roles:** membershipTier: 'free' | 'premium' | 'admin' stored in `profiles` table; admin check is simply `tier === 'admin'`
- **Account linking:** New OAuth logins that match an existing email inherit the old profile data (no email verification step)
- **Profile creation:** Supabase trigger `handle_new_user()` on `auth.users` INSERT, plus client-side RPC `get_or_create_profile` as fallback

🔴 **Risk:** Admin role is a plain string in `profiles.membership_tier` — any user who can write to their own row can escalate. An overly permissive INSERT RLS policy (`WITH CHECK (true)`) exists.

A5. Integrations

Integration	Purpose	Files
Supabase	DB, Auth, Storage, Edge Functions	supabase.ts
OpenAI (via Edge Function <code>ai-chat, ai-transcribe</code>)	AI coach chat, voice transcription	utils/aiService.ts, hooks/useVoiceInput.ts

Anthropic (via Edge Function <code>ai-chat</code>)	AI coach fallback	utils/aiService.ts
Stripe	Web subscription checkout/portal/webhooks	stripe.ts
Apple IAP / Google Play Billing	Native subscriptions	iap.ts, iap-android.ts
Fitbit API	Sleep, activity, heart rate	fitbit.ts
WHOOP API	Recovery, sleep, strain	whoop.ts
Oura Ring API	Sleep, readiness, activity	oura.ts
Garmin API (stub)	Sleep, HR, stress, body battery	garmin.ts
Expo Notifications	Local push scheduling	notifications.ts
No analytics SDK	—	—
No crash reporting	—	—

B) DATA + HEALTH DATA MAP

B1. Database Schema (Supabase Postgres)

Core tables (derived from supabase.ts types + routines-seed.sql + migration files):

Table	Key Columns	Written By
-------	-------------	------------

profiles	id, email, first_name, last_name, display_name, gender, birthday, membership_tier, stripe_customer_id, sakred_coins, current_streak, ai_consent, onboarding_completed	AuthContext, stripe, iap
wellness_routines	id, name, description, goal, duration_days, tier, category, icon, color, terrain_tags, who_is_this_for, what_to_expect, expected_results	Admin CRUD
routine_habits	id (UUID), routine_id, title, short_description, detailed_description, science_explanation, tips, expect_to_notice, cadence, recommended_time, duration_minutes, day_start, day_end, order_index, intensity, terrain_tags, icon	Admin CRUD
habit_routine_assignments	habit_id, routine_id	Admin CRUD
user_routines	id, user_id, routine_id, start_date, end_date, status, current_day, intensity, client_request_id	useRoutines

habits	id, user_id, user_routine_id, routine_habit_id, title, description, cadence, completed, scheduled_date, day_number, is_from_routine	useRoutines, useHabits
daily_habits (legacy)	id, user_id, title, description, cadence, completed, scheduled_date	useHabits
user_assigned_habits	id, user_id, habit_id, cadence, start_date, end_date	useHabitCatalog
journal_entries	id, user_id, content, mood, created_at	useJournal
dream_entries	id, user_id, content, clarity, emotions, themes, created_at	useDreamDiary
cycle_entries	id, user_id, date, flow_level, symptoms, notes	useCycle
health_data	id, user_id, provider, metric_type, value, date	wearablesSync
coin_transactions	id, user_id, amount, reason, created_at	AuthContext
products	id, name, description, price, image_url, routine_id	Admin CRUD
product_links	id, product_id, label, url, link_type	Admin CRUD

supplies	id, name, description, category	Admin CRUD
routine_supply_mappings	routine_id, supply_id	Admin CRUD
habit_supply_mappings	habit_id, supply_id	Admin CRUD
knowledge_documents / knowledge_chunks	user-uploaded docs	knowledgeBase
admin_knowledge_documents / admin_knowledge_chunks	admin training docs	adminKnowledgeBase
encyclopedia_articles / encyclopedia_chunks	curated wellness articles	encyclopedia
topic_requests	id, user_id, topic, details, status	topicRequests
apple_subscriptions	user_id, original_transaction_id, product_id, status, expires_date	iap
google_subscriptions	user_id, purchase_token, product_id, status, expires_date, order_id	iap-android

B2. Health-Related Fields (PHI candidates)

Table	Fields	Sensitivity
profiles	gender, birthday	PII + demographic health
journal_entries	mood (1-5), content (free text)	Mental health PHI

<code>dream_entries</code>	content, clarity, emotions, themes	Mental health PHI
<code>cycle_entries</code>	date, flow_level, symptoms, notes	Reproductiv e health PHI
<code>health_data</code>	sleep hours, steps, heart rate, HRV, recovery score, stress	Biometric PHI
habits / <code>user_routines</code>	routine enrollment, intensity, completion status	Health behavior data (PHI when linked to identity)
<code>knowledge_documents</code>	user-uploa ded wellness documents	Potentially PHI

B3. Client-Side vs Server-Side Storage

Storage Location	What	Encrypted ?
AsyncStorage (client)	Supabase JWT tokens, AI consent prefs, notification settings, appearance mode, walkthrough flags, wearable connection cache	 No

SecureStore (client, native only)	Fitbit/WHOOP/Oura/Garmin OAuth tokens	✓ Yes (native keychain)
Supabase Postgres (server)	All tables above	✓ At rest (Supabase managed)
Supabase Edge Functions (server)	OpenAI/Anthropic API keys, Stripe secrets, service role key	✓ Env-injected

● **Critical:** Supabase session tokens (full JWT with user_id, email, role) stored in plaintext AsyncStorage. On jailbroken/rooted devices, trivially readable.

B4. Data Sent to Third Parties

Recipient	Data Sent	Source
OpenAI / Anthropic (via ai-chat)	Display name, gender, age, mood history, dream themes/emotions, habit names/completions, active routine name, cycle phase, wearable biometrics (sleep, HR, HRV, recovery), Sacred Coins, personal knowledge base docs	aiPrivacy.ts
OpenAI (via ai-transcribe)	Raw audio recordings	hooks/useVoiceInput.ts
Stripe	Email, customer ID	stripe.ts
Apple / Google (IAP)	Purchase tokens, transaction IDs	iap.ts

Fitbit / WHOOP / Oura / Garmin	OAuth tokens; receives biometric data	fitbit.ts, etc.
Expo (push)	Device push token	notifications.ts

 **Critical:** The AI context builder in aiPrivacy.ts sends a comprehensive health profile to LLM providers on every chat message. Consent defaults are **all true** (opt-out model).

B5. Secrets & Key Loading

Secret	Location	Risk
<code>EXPO_PUBLIC_SUPABASE_URL</code> + <code>EXPO_PUBLIC_SUPABASE_ANON_KEY</code>	Hardcoded in eas.json <code>production.env</code> block + .env file	 Anon key is designed to be public but .env is NOT in .gitignore
Wearable client IDs/secrets	<code>EXPO_PUBLIC_*</code> env vars	 Client IDs exposed in bundle
<code>OPENAI_API_KEY</code> , <code>ANTHROPIC_API_KEY</code>	Supabase Edge Function secrets	 Server-only
<code>STRIPE_SECRET_KEY</code> , <code>STRIPE_WEBHOOK_SECRET</code>	Supabase Edge Function secrets	 Server-only
<code>SUPABASE_SERVICE_ROLE_KEY</code>	Supabase Edge Function secrets	 Server-only but  used in all edge functions as admin client

C) COMPLIANCE GAP ANALYSIS

C1. HIPAA-Risk Touchpoints

#	Risk	Severity	Location
1	PHI sent to OpenAI/Anthropic — journal content, mood, cycle phase, biometrics, dream emotions all included in AI system prompt. No BAA with OpenAI/Anthropic.	 CRITICAL	aiPrivacy.ts <code>buildAIContext()</code>
2	Supabase hosting — no BAA signed with Supabase. All PHI tables hosted there.	 CRITICAL	All tables
3	Cycle prediction in push notification body — visible on lock screen	 HIGH	notifications.ts cycle reminder
4	Session tokens in plaintext AsyncStorage	 HIGH	supabase.ts <code>AsyncStorage</code> adapter
5	Console.log leaks emails and user IDs in production — no babel strip plugin	 MEDIUM	AuthContext.tsx multiple log lines
6	No audit logging for data access or modifications	 MEDIUM	Entire codebase
7	Voice audio recordings sent to OpenAI for transcription — PHI in speech	 MEDIUM	hooks/useVoiceInput.ts

C2. Access Control Issues

#	Risk	Severity	Location
1	<code>trigger_can_insert</code> RLS policy: <code>WITH CHECK (true)</code> on <code>profiles</code> — any authenticated user can INSERT a row with <code>membership_tier: 'admin'</code>	 CRITICAL	<code>supabase_comprehensive_fix.sql</code>
2	Admin role = string in profiles table — no cryptographic verification, no separate RBAC	 HIGH	<code>AuthContext.tsx</code>
3	<code>anon</code> role has SELECT on <code>profiles</code> — unauthenticated reads possible	 MEDIUM	<code>supabase_comprehensive_fix.sql</code>
4	Account linking by email without verification — OAuth login inherits existing profile	 MEDIUM	<code>AuthContext.tsx</code> <code>adoptExistingProfile</code>
5	Missing RLS for PHI tables — no version-controlled policies for <code>journal_entries</code> , <code>dream_entries</code> , <code>cycle_entries</code> , <code>health_data</code> , <code>habits</code> , <code>user_routines</code>	 MEDIUM	No SQL files found
6	Admin screens gated only by client-side <code>membershipTier</code> check — no server-side admin enforcement	 MEDIUM	<code>SettingsScreen.tsx</code>

C3. Audit Logging Gaps

- **No audit log table exists.** Zero server-side tracking of who accessed or modified PHI.
- No logging of admin actions (routine/habit/product CRUD, topic request management, AI training uploads).
- No logging of data exports, account deletions, or subscription changes.
- **Required:** Immutable append-only `audit_log` table tracking (`user_id`, `action`, `resource_type`, `resource_id`, `timestamp`, `ip_address`).

C4. Encryption Gaps

Layer	Status
In transit	 HTTPS/TLS enforced by Supabase and all API endpoints

At rest (server)	✔ Supabase managed encryption (but no customer-managed keys)
At rest (client)	● Session tokens + AI consent + health cache in plaintext AsyncStorage
Key management	● No KMS. Supabase manages encryption keys. No customer control.
Field-level encryption	● None. Journal content, cycle data, dream content stored as plaintext in DB

C5. Data Retention & Deletion Gaps

- **Account deletion** exists in SettingsScreen — calls Supabase to delete user data.
- **No documented retention policy.** Data persists indefinitely.
- **No automated data purge** for inactive accounts.
- **No data export** (right of access) functionality.
- **Wearable health cache** in AsyncStorage persists indefinitely with no expiration.

C6. AI-Specific Risks

Risk	Detail
PHI leakage to LLM	Full health context (mood, cycle, biometrics, journal text) sent on every message
Prompt injection	User messages sent directly to LLM with system prompt — no input sanitization
Unsafe health advice	AI can produce wellness recommendations; MedicalDisclaimer component exists but is easily skipped
Consent model	Opt-out: all AI data sharing defaults to <code>true</code> in aiPrivacy.ts

Chat log retention	✔ Not persisted server-side (component state only)
No content filtering	No output validation/filtering on LLM responses

C7. Mobile-Specific Risks

Risk	Detail
Lock screen PHI	Cycle prediction notifications visible on lock screen
Local caching	Health data cached in unencrypted AsyncStorage
No crash reporting	No Sentry/Bugsnag — but this also means no PHI in crash reports (a positive)
Jailbreak/root detection	None implemented
Screenshot/screen recording	No protection on sensitive screens
App backgrounding	No screen blur/mask when app enters background

D) "PRIVATE-SECTOR MODE" PLAN

D1. Feature Differences

Feature	Consumer Mode	Private-Sector Mode	Rationale
Parasite Cleanse routines	✔ Show	✗ Hide	Medical claims risk
Heavy Metal Detox routines	✔ Show	✗ Hide	Medical claims risk
"Detox" category label	✔ Show	↻ Rename → "Reset"	Regulatory language
"Terrain Theory" AI translator	✔ Show	✗ Hide	Not evidence-based for clinical
Cycle tracking	✔ Show	⚙ Opt-in only	Sensitive PHI, liability
Dream diary	✔ Show	✗ Hide	Mental health liability
Journal (mood + text)	✔ Show	↻ Simplified "check-in" (mood only, no free text)	Reduces PHI surface
AI Coach (full chat)	✔ Show	↻ Scoped to adherence tips only (no health interpretations)	Liability + PHI risk
Wearable integrations	✔ Show	✔ Show (steps, sleep hours only — no HR/HRV/recovery)	Limit biometric PHI
Hydration habits	✔ Show	✔ Show	Safe wellness

Sleep rhythm habits	✓ Show	✓ Show	Safe wellness
Stress reduction habits	✓ Show	✓ Show	Safe wellness
Digestion stability habits	✓ Show	✓ Show	Safe wellness
Cravings control habits	✓ Show	✓ Show	Safe wellness
Basic movement habits	✓ Show	✓ Show	Safe wellness
Adherence tracking	✓ Show	✓ Show (core value prop)	Participation scoring
Gamification (coins/badges)	✓ Show	↻ Rename → "Engagement Points"	Professional framing
Product recommendations	✓ Show	✗ Hide	Conflict of interest risk
Subscription paywall	✓ Show	↻ Employer/broker pays (no consumer paywall)	B2B model
Admin tools	✓ Show	↻ Expand for broker/employer admin	New roles needed
Participation reports	✗ N/A	✓ New: exportable engagement reports	Core B2B deliverable
Consent flows	Basic AI consent	↻ Full HIPAA-grade	Compliance requirement

		consent + data use agreement	
--	--	---------------------------------	--

D2. UI/UX Differences

Screens to ADD in private-sector mode:

- `ConsentScreen` — HIPAA-grade data use agreement with explicit opt-in checkboxes
- `ParticipationReportScreen` — member view of their own engagement scores
- `AdminReportScreen` — broker/employer view of aggregate (de-identified) participation data
- `DataExportScreen` — member can request full data export (right of access)
- `OrganizationScreen` — member sees which organization/group they belong to

Screens to HIDE in private-sector mode:

- `DreamDiaryScreen`
- `RewardsScreen` (replace with simplified engagement view)
- AI Terrain Translator tab in `AICoachScreen`

Screens to MODIFY:

- `RoutineSelectionScreen` — filter out category: 'detox' routines with flagged keywords (parasite, heavy metal)
- `AICoachScreen` — restrict system prompt to adherence/motivation only; strip health interpretation capability
- `JournalEntryScreen` — mood-only mode, disable free-text field
- `OnboardingScreen` — add organization code entry + consent flow
- `DashboardScreen` — replace "Start a Cleanse" card with "Start a Wellness Routine"

D3. Data Differences

New tables needed:

Table	Purpose
<code>organizations</code>	id, name, type (employer/broker/clinic), created_at
<code>organization_members</code>	id, organization_id, user_id, role (member/admin/broker), joined_at
<code>consent_records</code>	id, user_id, consent_type, version,

	accepted_at, ip_address, revoked_at
audit_log	id, user_id, action, resource_type, resource_id, metadata, ip_address, created_at
participation_scores	id, user_id, organization_id, period (weekly/monthly), score, breakdown_json, computed_at
data_export_requests	id, user_id, status, requested_at, completed_at, download_url, expires_at

Fields to disable/null in private-sector mode:

- journal_entries.content → null (mood-only)
- dream_entries → entire table disabled
- health_data where metric_type in ('heart_rate', 'hrv', 'recovery_score') → not synced
- cycle_entries → opt-in only, with separate consent record

New column on profiles:

- app_mode: 'consumer' | 'private_sector'
- organization_id: UUID | null

D4. Roles

Role	Scope	Access
Member	Own data	View/edit own habits, routines, journal check-ins; view own participation score
Org Admin	Organization	View aggregate (de-identified) participation reports

		for their org; manage member invites
Broker/Agent	Multi-org	View aggregate reports across organizations; no individual member data
System Admin	Global	Routine/habit/product CRUD; AI training; user management (existing admin role)

D5. Participation-Based Engagement Scoring

Scoring model (NOT outcomes-based):

Activity	Points	Cap
Daily habit check-off	2 per habit	20/day
Journal mood check-in	5	5/day
Wearable data sync	3	3/day
Routine active day	5	5/day
Weekly streak bonus	10	10/week

Weekly score = sum of daily points (max ~33/day = 231/week)

Reports:

- Member sees: own weekly/monthly score, trend chart, streak
- Org Admin sees: average participation rate, distribution histogram, active member %, top routines by adoption — **all aggregate, no individual names**
- Export: CSV/PDF with organization-level statistics only

D6. Consent & Privacy UX Flows

First launch (private-sector mode):

1. Organization code entry → validates against `organizations` table
2. Auth (email/Apple/Google)
3. **HIPAA consent screen** — explicit checkboxes:
 - "I understand my wellness participation data will be shared in aggregate with my organization"
 - "I consent to my habit and routine data being stored securely"
 - "I understand I can withdraw consent and delete my data at any time"
 - Digital signature (typed name + timestamp)
4. Record stored in `consent_records` with version number
5. Onboarding (simplified: no gender/birthday required)

Ongoing:

- Settings → "Privacy & Consent" section showing active consents with revoke option
- Settings → "Export My Data" button
- Settings → "Delete My Account" (existing, but must also notify organization admin)

E) IMPLEMENTATION ROADMAP

MVP (Weeks 1–4): Make Private-Sector Mode Viable

Must-do:

#	Task	Files	Acceptance Criteria
1	Add <code>app_mode</code> to <code>profiles</code> + mode-switching logic	AuthContext.tsx, supabase.ts, new migration SQL	Profile has <code>app_mode</code> column; UI reads it to gate features
2	Content filter: hide detox/parasite routines	RoutineSelectionScreen.tsx, useRoutines.ts	Private-sect or mode hides routines with flagged keywords; consumer mode unchanged

3	Restrict AI system prompt in private-sector mode	aiPrivacy.ts, utils/aiService.ts	Private-sector AI context excludes cycle data, dream data, journal text; limits to adherence coaching
4	Fix RLS critical: remove <code>trigger_can_insert</code> policy, lock <code>profiles</code> INSERT to <code>auth.uid()</code> only	supabase_comprehensive_fix.sql	No user can insert profiles for other users or set admin tier
5	Add RLS for PHI tables (<code>journal_entries</code> , <code>dream_entries</code> , <code>cycle_entries</code> , <code>health_data</code> , <code>habits</code> , <code>user_routines</code>)	New migration SQL	Each table: SELECT/UPDATE/DELETE restricted to <code>auth.uid() = user_id</code>
6	Move session tokens to SecureStore on native	supabase.ts	JWT tokens encrypted at rest on iOS/Android
7	Fix push notification PHI — remove cycle content from notification body	notifications.ts	Cycle reminders use generic text: "Check your wellness tracker"
8	Flip AI consent defaults to <code>false</code> (opt-in)	aiPrivacy.ts	All AI data sharing is opt-in
9	Add <code>audit_log</code> table + trigger for profile changes and routine enrollments	New migration SQL	Every profile update and enrollment

			creates an audit record
1 0	Strip console.log PII — add babel-plugin-transform-remove-console for production	babel.config.js	Production builds contain zero console output

Nice-to-have (MVP):

- Simplified journal (mood-only mode toggle)
- Organization code entry on onboarding

v1 (Weeks 5–8): Organization & Reporting

Must-do:

#	Task	Files
1	Create <code>organizations</code> , <code>organization_members</code> , <code>consent_records</code> tables with RLS	New migration SQL
2	Build HIPAA consent screen	New <code>screens/ConsentScreen.tsx</code> , update <code>RootNavigator.tsx</code>
3	Build participation scoring engine (server-side Edge Function, runs nightly)	New Edge Function <code>compute-participation</code>
4	Build member participation report screen	New <code>screens/ParticipationReportScreen.tsx</code>
5	Build org admin report screen (aggregate only)	New <code>screens/AdminReportScreen.tsx</code>
6	Add data export endpoint (Edge Function → generates ZIP of user's data)	New Edge Function data-export
7	Server-side enrollment validation — move <code>enrollInRoutine</code> critical logic to an Edge Function	New Edge Function <code>enroll-routine</code> , update <code>useRoutines.ts</code>

8	Add org-aware onboarding — org code entry + consent before main app	OnboardingScreen.tsx
---	--	----------------------

v2 (Weeks 9–12+): Full HIPAA Hardening

Must-do:

#	Task
1	Migrate Supabase to a BAA-covered provider (Supabase Pro with BAA, or self-hosted Postgres on AWS/GCP with BAA)
2	Implement customer-managed encryption keys for PHI tables
3	Add MFA requirement for admin and broker roles
4	Add jailbreak/root detection — warn users on compromised devices
5	Add app background blur — mask sensitive screens when app backgrounds
6	Penetration testing and remediation
7	BAA execution with OpenAI (or switch to Azure OpenAI which offers BAA)
8	Formal HIPAA Risk Assessment documentation
9	Data retention automation — configurable retention periods per org with auto-purge

10	WCAG 2.1 AA accessibility audit — verify contrast, labels, font scaling, screen reader flows across all screens
----	--

Workstream Summary

Workstream	MVP	v1	v2
Access Control & RLS	Fix critical RLS, lock admin role	Org-based RBAC	MFA, jailbreak detection
Data Protection	SecureStore tokens, strip logs, fix push PHI	Consent records, data export	KMS, BAA migration, retention automation
AI Compliance	Flip consent to opt-in, restrict private-sect or prompt	Server-side validation	Azure OpenAI BAA, content filtering
Feature Gating	Content filter for routines, app_mode column	Full dual-mode UI	—
Reporting	—	Participation scoring + reports	Export formats, broker dashboards
Audit	audit_log table + basic triggers	Comprehensive event logging	Immutable log storage, retention